

Clase 303 — Capstone: laboratorio completo de pentest

Parte: **16 — Capstones y preparación de certificaciones** · Fuente: *NIST SP 800-115 · PTES · Georgia Weidman, Penetration Testing* ⌚ Duración estimada: **150 min** · Nivel: **Avanzado**

Objetivo

Ejecutar un **pentest end-to-end** contra un laboratorio propio multi-máquina, siguiendo una metodología profesional (PTES / NIST SP 800-115) y entregando un **informe formal** con hallazgos, puntuación CVSS y recomendaciones de remediación. Este capstone integra las Partes 6 (web), 7 (redes/infra), 8 (Active Directory) y 9 (post-explotación) en un único proyecto verificable.

⚠ **Ética y legalidad:** el objetivo es tu **propio laboratorio** (VulnHub, máquinas construidas por ti, un rango AD de práctica). Nunca ejecute este capstone contra sistemas de terceros sin autorización escrita.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Planificar** un pentest con alcance, reglas de enfrentamiento y objetivos definidos.
2. **Ejecutar** las 7 fases de PTES contra un entorno realista.
3. **Puntuar** hallazgos con CVSS 3.1 y priorizarlos por riesgo.
4. **Redactar** un informe con resumen ejecutivo, hallazgos técnicos y remediación.
5. **Defender** los resultados en una reunión de cierre (readout).

Temas

#	Tema	Por qué importa
1	Alcance y reglas de enfrentamiento	Define límites legales y técnicos
2	Fases PTES	Estructura profesional del trabajo
3	Enumeración e intel (Parte 6–7)	Base de todo hallazgo
4	Explotación y pivoting (Parte 9)	Demostrar impacto real
5	Active Directory (Parte 8)	Escenario empresarial típico
6	CVSS y priorización	Comunicar riesgo objetivamente
7	Informe y readout	El entregable que paga el cliente

Definiciones y características

- **Alcance (scope):** activos y técnicas autorizadas. *Característica:* todo lo fuera de alcance está prohibido.
- **Reglas de enfrentamiento (RoE):** horarios, límites, contactos de emergencia. *Característica:* evitan incidentes y disputas legales.
- **PTES:** estándar de 7 fases (pre-engagement, intel, modelado de amenazas, análisis de vulnerabilidades, explotación, post-explotación, reporte). *Característica:* marco reproducible.
- **CVSS 3.1:** sistema de puntuación de severidad 0–10. *Característica:* separa base, temporal y ambiental.
- **Resumen ejecutivo:** sección para directivos sin jerga. *Característica:* enfoca riesgo de negocio, no comandos.
- **Retest:** verificación de que las remediaciones funcionan. *Característica:* cierra el ciclo.

Herramientas y preparación

- Laboratorio: 3–5 VMs (mezcla de VulnHub + un rango AD tipo *GOAD* o *DetectionLab*).
- Recon/explotación: `nmap`, `autorecon`, `ffuf`, `BloodHound`, `impacket`, `CrackMapExec`, `Metasploit`.
- Post-explotación: `mimikatz`, `secretsdump.py`, `chisel` / `ligolo` para pivoting.
- Gestión: Obsidian/CherryTree para notas, plantilla de informe (Markdown o Word).
- CVSS calculator (FIRST.org).

Laboratorio guiado

Solo contra tu propio laboratorio.

1. **Pre-engagement.** Escribe un documento de alcance: IPs objetivo, ventana de tiempo, técnicas permitidas, objetivos ("obtener Domain Admin y exfiltrar `flag.txt`").
2. **Recon e intel.** Enumera toda la red: `nmap -p- --min-rate 2000` a cada host y `-sVC` a los puertos abiertos.
3. **Análisis de vulnerabilidades.** Cruza servicios con `searchsploit`; identifica web (OWASP Top 10 de la Parte 6), SMB, y rutas AD.
4. **Explotación inicial.** Consigue foothold en la máquina más expuesta; documenta el comando y captura evidencia.
5. **Pivoting.** Levanta un túnel (`ligolo-ng` o `chisel`) hacia la red interna no enrutable.
6. **Ataque a Active Directory.** Ejecuta `bloodhound-python`, analiza rutas de ataque, abusa de Kerberoasting/AS-REP y escala a Domain Admin con `secretsdump.py`.
7. **Post-explotación.** Recolecta evidencia del objetivo (flag), sin causar daño ni persistencia innecesaria.
8. **Puntuación.** Asigna CVSS 3.1 a cada hallazgo con el calculador de FIRST.
9. **Informe.** Redacta resumen ejecutivo, hallazgos (descripción, evidencia, CVSS, remediación) y anexos.
10. **Readout.** Prepara 5 diapositivas y explica el riesgo de negocio en 10 minutos.

Ejercicios

1. Redacta el documento de alcance y RoE de tu laboratorio.
2. Genera un mapa de red con hosts, servicios y hallazgos.

3. Puntúa tres hallazgos con CVSS y justifica cada métrica.
4. Escribe el resumen ejecutivo (máx. media página, sin jerga).
5. Documenta una cadena de ataque completa foothold → Domain Admin.
6. Propón remediaciones priorizadas por coste/impacto.

Reto verificable

Entrega un **informe de pentest** completo (`informe-pentest.pdf` o `.md`) del laboratorio, con al menos: alcance, metodología, 5 hallazgos con CVSS, una cadena de ataque hasta el objetivo final, y recomendaciones. Adjunta el cuaderno de notas con evidencias.

Criterio de aceptación: el informe permite a un tercero reproducir cada hallazgo, cada CVSS es coherente con el vector descrito, hay un resumen ejecutivo sin jerga, y se alcanzó el objetivo definido en el alcance (p. ej. Domain Admin + flag).

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"El informe es solo comandos"	Falta contexto de riesgo; añade resumen ejecutivo y remediación.
"No puedo llegar a la red interna"	Falta pivoting; configura túnel con ligolo/chisel.
"BloodHound no muestra rutas"	Recolección incompleta; usa <code>bloodhound-python -c ALL</code> .
"CVSS inflado"	Métricas mal elegidas; revisa vector de ataque y alcance real.
"Rompí una VM"	Explotación agresiva sin snapshot; usa snapshots antes de cada fase.

Preguntas frecuentes

? ¿Qué laboratorio uso si no tengo AD? Despliega *GOAD* (Game of Active Directory) o *DetectionLab*; son gratuitos y reproducibles.

? ¿Cuánto debe medir el informe? Lo necesario: un resumen ejecutivo breve y hallazgos detallados. Calidad sobre cantidad.

? ¿Incluyo hallazgos de bajo riesgo? Sí, pero priorizados. Un informe profesional cubre todo el espectro con severidad clara.

? ¿Este capstone sirve para el OSCP? Sí: la redacción del informe y la metodología son directamente aplicables al examen (ver Clase 302).

Referencias

- NIST SP 800-115: <https://csrc.nist.gov/pubs/sp/800/115/final>
- PTES: <http://www.pentest-standard.org/>
- CVSS 3.1 Calculator (FIRST): <https://www.first.org/cvss/calculator/3.1>
- GOAD: <https://github.com/Orange-Cyberdefense/GOAD>
- BloodHound: <https://github.com/BloodHoundAD/BloodHound>

Siguiente clase

Clase 304 - Preparacion CISSP: los 8 dominios